

Autenticação e Autorização

Login, sessão, cookies, tokens, JWT, OAuth, OIDC, SSO, MFA e controle de acesso.

Authentication x Authorization

Autenticação responde quem é o usuário. Autorização define o que esse usuário pode fazer. Um usuário autenticado acessar uma função administrativa sem permissão é uma falha de autorização.

Sessões e tokens

Aplicações podem usar cookies de sessão ou tokens. JWT é um formato de token; OAuth 2.0 é um framework de autorização; OpenID Connect adiciona uma camada de identidade sobre OAuth 2.0.

SSO e MFA

Single Sign-On permite reutilizar uma identidade entre aplicações. Multi-Factor Authentication exige fatores adicionais e precisa ser testado em sucesso, falha, recuperação e expiração.

Cenários de QA

Valide credenciais inválidas, logout, expiração, acesso por perfil, troca de usuário, URLs protegidas, sessão simultânea e mensagens de erro sem exposição indevida.

Quando usar

Use este conhecimento quando o risco, a arquitetura ou a etapa do ciclo de desenvolvimento exigir validação específica. Antes de aplicar, confirme objetivo, ambiente, dados necessários e evidências esperadas.

Como o QA aplica na prática

Comece pelo comportamento ou risco que precisa ser validado, prepare dados e ambiente, execute a técnica ou ferramenta de forma reproduzível e registre evidências que permitam explicar o resultado ao time.

Dica de QA

Login funcionando não prova que autorização está correta: sempre teste perfis e recursos protegidos.

Recursos oficiais

Site oficial: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html